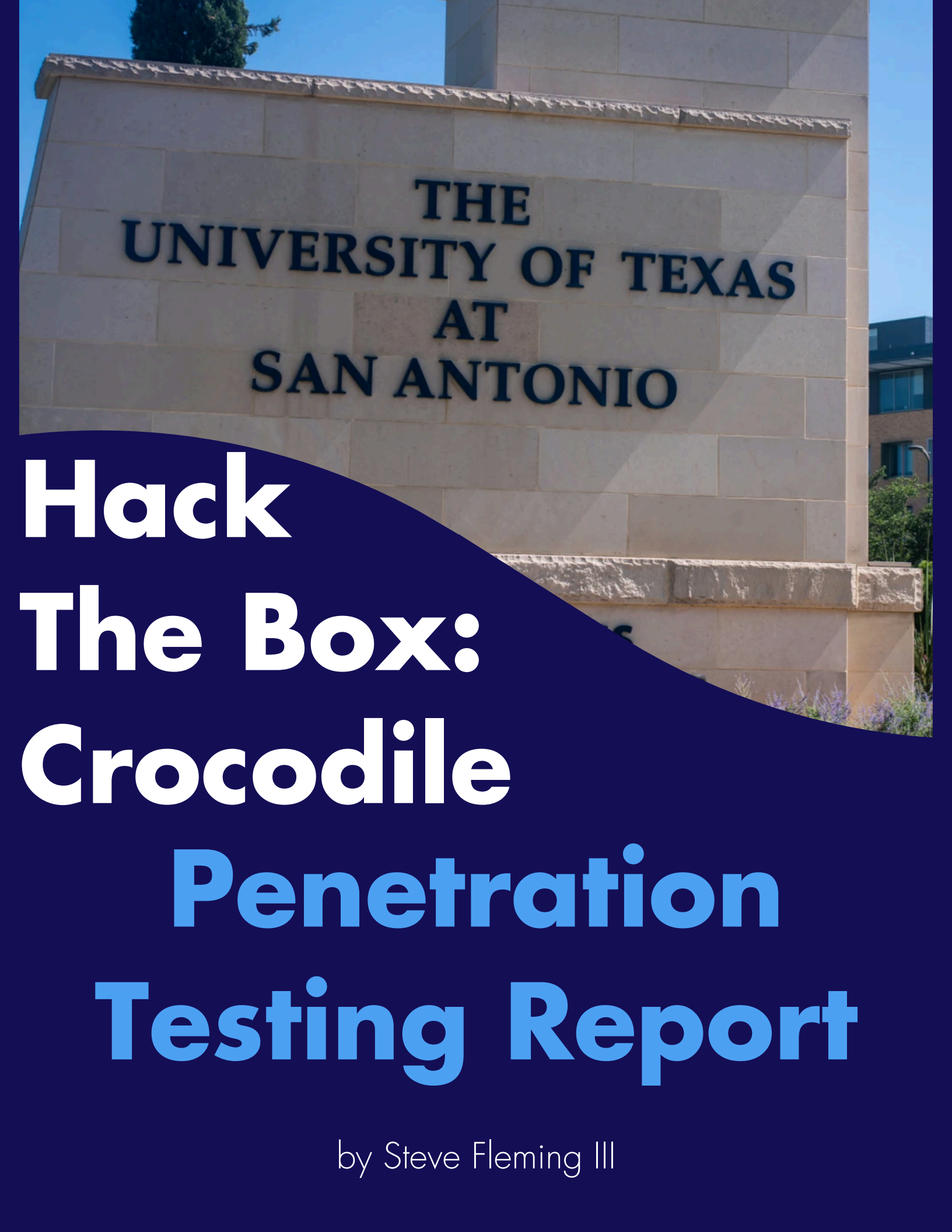


A photograph of a stone wall with the text 'THE UNIVERSITY OF TEXAS AT SAN ANTONIO' carved into it. The wall is made of light-colored stone blocks. The text is in a dark, serif font. The wall is part of a larger building, and a modern building with glass windows is visible in the background to the right. The sky is clear and blue.

THE
UNIVERSITY OF TEXAS
AT
SAN ANTONIO

Hack The Box: Crocodile Penetration Testing Report

by Steve Fleming III

This assessment contains critical information for the Crocodile box created by the company Hack the Box. Everything contained in the report should be considered property of Crocodile and there has been information censored as it was deemed unnecessary for the report.

Abstract

During the assessment of Crocodile, a critical weakness related to a misconfiguration of an ftp server was found which allowed for administrator level access to the hosted website. Crocodile was designed to follow best practices in other areas of cybersecurity showing strengths in its design while still being a learning platform. In the pursuit of learning, patching all vulnerabilities that were found would make a starting level box more difficult to complete. Nonetheless, we do have recommendations regarding encryption that would preserve the beginner nature of the box while adding an additional layer of learning and strength.

Table of Contents

Abstract	3
1 Introduction	7
1.1 Background	7
1.2 Scope	7
1.3 Layout	7
2 System Summary.....	8
2.1 Active Ports	8
3 Assessment Methodologies.....	9
3.1 PTES Model.....	9
3.1.1 Pre-Engagement Interaction.....	9
3.1.2 Intelligence Gathering.....	9
3.1.3 Threat Modeling.....	10
3.1.4 Vulnerability Analysis.....	10
3.1.5 Exploitation.....	10
3.1.6 Post-Exploitation.....	10
3.1.7 Reporting.....	11
4 Assessment Activities	12
4.1 Environment Setup.....	12
4.2 Network Information Gathering.....	13
4.3 FTP Findings.....	13
4.4 Hack the Box Tasks.....	14
4.5 Website Enumeration.....	14
4.6 Administrative Access Validation.....	14
5 Assessment Results and Recommendations.....	16
5.1 Weaknesses....	16
5.2 Strengths.....	17
5.3 Observations.....	17
6 Conclusion	19
7 Appendix A: NMAP Scan Summary.....	20
7.1 Definition.....	20
7.2 Raw Output.....	20
7.3 Command Explanation.....	21

7.4 Scan Summary.....	21
8 Appendix B: GOBUSTER Scan Summary.....	22
8.1 Definition.....	22
8.2 Raw Output.....	22
8.3 Command Explanation.....	23
8.4 Scan Summary.....	23
9 Appendix C: Additional Definitions.....	24
9.1 FTP.....	24
9.2 HTTP.....	24

Figures

Figure 1: Pwnbox Boot Confirmation	12
Figure 2: Target Machine Information.....	12
Figure 3: Userlist and Passwords.....	13
Figure 4: Login Page.....	15
Figure 5: Administrator Page.....	15
Figure 6: Raw nmap Output.....	20
Figure 6: Raw gobuster Output.....	22

1 Introduction

We will use this section to give background as to why the penetration test was performed, the scope of the test, and layout of the report.

1.1 Background

Hack The Box is an educational platform that specializes in cybersecurity and penetration testing in a secure environment. This allows students to ability to practice without being in a live environment. The Penetration Testing class offered by the University of Texas at San Antonio utilizes the Hack The Box platform and requires students to complete their boxes as part of its curriculum. This report will focus on the box named Crocodile which is part of the Tier 1 in the Starting Point category.

1.2 Scope

While Hack The Box offers a variety of different boxes and challenges this report will focus solely on the Crocodile box. Limited to the Crocodile box under Tier 1 of the Starting Point category, none of the other boxes offered by Hack the Box will be mentioned or reviewed. As part of their learning curriculum, Hack the Box provides guidance questions to focus students to the intended way of completing the box. The penetration test will also be limited to the guidance tasks provided by Hack the Box.

1.3 Layout

This report will contain the following organization: Section 2 will be an overview of the Crocodile box and its systems, Sections 3 and 4 cover steps taken during the assessment, Section 5 will contain the results of the penetration test and any recommendations, Section 6 will conclude the report, and Sections 7, 8 and 9 contain appendices that review further details of the assessment

2 System Summary

The goal of the Starting Point section of Hack the Box is to start students off on very simple boxes to build up experience. All of the boxes are focused on teaching something specific and as a result, the systems are not very complex. Crocodile is no exception and has only a handful of systems running while in use.

Crocodile is run in a contained environment, a virtual machine is started and assigned an IP address that is instanced per user. These virtual machines are isolated with the Hack the Box network and can be accessed using OpenVPN or their proprietary virtual machine they call a Pwnbox. Pwnbox can run in the browser and comes equipped with all the tools necessary to complete the box. This test was completing using a Pwnbox and during the test, the IP address we were assigned was: 10.129.35.216.

2.1 Active Ports

Using nmap, we were able to find 2 ports open in the Crocodile box. The nmap tool checks the first 1000 ports but we used a different flag to scan 65,535. There will be further information in Sections 4 and 7 on the specifics of the nmap scan.

The scan resulted in 2 ports in an open state, port 21 which is used for ftp, or file transfer protocol, and port 80 which is used for http, or hyper text transfer protocol.

Further information about ftp and http will be located in Section 9.

3 Assessment Methodology

During the semester, emphasis has been placed on a few different assessment methodologies. For this assessment we used the PTES (Penetration Testing Execution Standard) model. This section will explain each step of the PTES model, these summaries were provided by ChatGPT.

3.1 PTES Model

The Penetration Testing Execution Standard (PTES) is a comprehensive framework designed to standardize the way penetration tests are planned, conducted, and reported. It provides a structured methodology that guides security professionals through every stage of an assessment, ensuring consistency, thoroughness, and alignment with real-world attack scenarios. PTES is widely respected because it not only addresses the technical aspects of penetration testing but also emphasizes planning, communication, risk evaluation, and remediation. By following PTES, organizations can gain a clearer understanding of their security posture and identify vulnerabilities before malicious actors exploit them.

3.1.1 Pre-Engagement Interaction

The pre-engagement phase is the foundation of a successful penetration test. During this stage, the client and the testing team work together to define the scope, objectives, and rules of engagement. This includes determining which systems, applications, and networks will be tested, establishing timelines, and clarifying the goals of the assessment. Legal authorization is obtained at this point, along with agreements regarding communication procedures and escalation paths in the event of critical findings. Proper planning during this phase helps prevent misunderstandings, ensures legal compliance, and sets clear expectations for all parties involved.

3.1.2 Intelligence Gathering

Intelligence gathering focuses on collecting information about the target environment. The objective is to build a detailed understanding of the organization's external and internal attack surface. This can involve passive reconnaissance, such as reviewing publicly available information on websites, social media platforms, domain registrations, and public records. It may also include active reconnaissance techniques, such as network scanning, service enumeration, and DNS analysis. The information collected during this phase helps identify potential entry points and provides the context needed for later stages of testing.

3.1.3 Threat Modeling

Threat modeling uses the information gathered to identify likely attack paths and prioritize areas of greatest risk. In this phase, the tester considers the organization's most valuable assets, the types of adversaries that might target them, and the techniques those adversaries are likely to use. This analysis helps determine which systems and vulnerabilities pose the greatest threat to the organization. By focusing on realistic attack scenarios, threat modeling ensures that the penetration test aligns with actual business risks rather than simply identifying technical weaknesses in isolation.

3.1.4 Vulnerability Analysis

During vulnerability analysis, the tester identifies and validates security weaknesses within the target environment. These weaknesses may include software vulnerabilities, insecure configurations, weak authentication mechanisms, inadequate access controls, or flaws in application logic. Automated scanning tools are often used to identify potential issues, but manual verification is essential to confirm their validity and eliminate false positives. This phase provides a detailed understanding of the vulnerabilities present and helps prioritize them based on their exploitability and potential impact on the organization.

3.1.5 Exploitation

Exploitation involves actively attempting to leverage identified vulnerabilities to gain unauthorized access or demonstrate their potential impact. This phase validates whether a vulnerability can be successfully exploited in a real-world scenario. Testers may attempt to gain system access, escalate privileges, bypass security controls, or retrieve sensitive information. Successful exploitation demonstrates the practical risk posed by a vulnerability and helps organizations understand the severity of their security weaknesses. The goal is not merely to compromise systems, but to provide evidence of risk in a controlled and authorized manner.

3.1.6 Post-Exploitation

Post-exploitation examines the extent of access gained and the potential consequences of a successful attack. Once initial access is achieved, the tester assesses what additional actions an attacker could perform within the environment. This may include escalating privileges, moving laterally across the network, accessing sensitive data, or establishing persistence. The purpose of this phase is to evaluate the true business impact of a compromise. It helps organizations understand how an attacker could leverage one vulnerability to achieve broader objectives and compromise additional assets.

3.1.7 Reporting

Reporting is the final and arguably most important phase of the PTES methodology. The findings from the engagement are documented in a clear, detailed, and actionable report tailored to both technical and non-technical audiences. The report typically includes an executive summary that outlines the overall security posture, as well as technical sections describing vulnerabilities, exploitation methods, evidence, and remediation recommendations. Effective reporting translates technical findings into business risk, enabling stakeholders to make informed decisions and prioritize corrective actions. A well-written report ensures that the value of the penetration test extends beyond the assessment itself and contributes to long-term security improvement.

4 Assessment Activities

In this section we will go over the various steps taken to complete the Crocodile box. This will include connecting to the box, hack the box guidance tasks, results of the nmap scan, results of the gobuster tool, and showing the completed box.

4.1 Environment Setup

As mentioned in Section 2, we used the proprietary Pwnbox to complete the assessment and Crocodile box tasks. In order to connect, you must make sure to boot the Pwnbox under the Starting Point section in the same VPN server as the target machine.

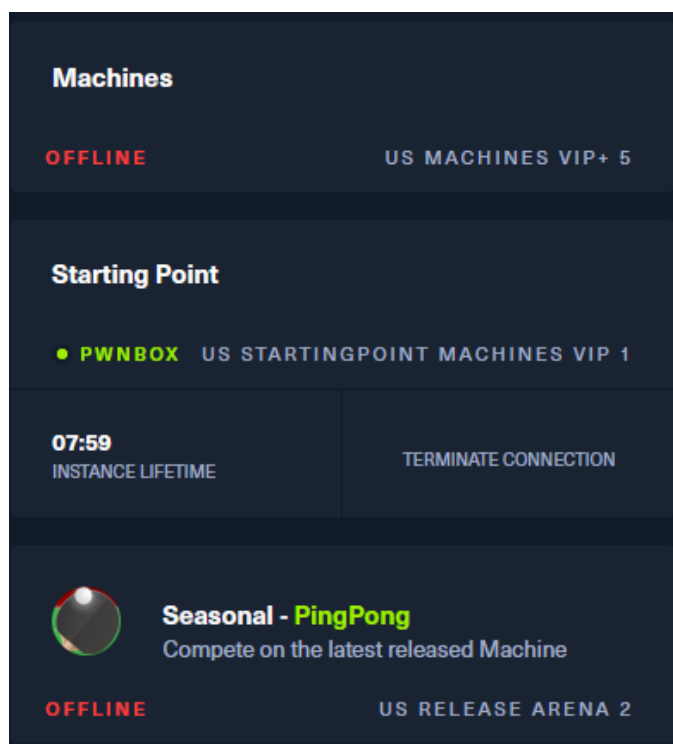


Figure 1: Pwnbox Boot Confirmation

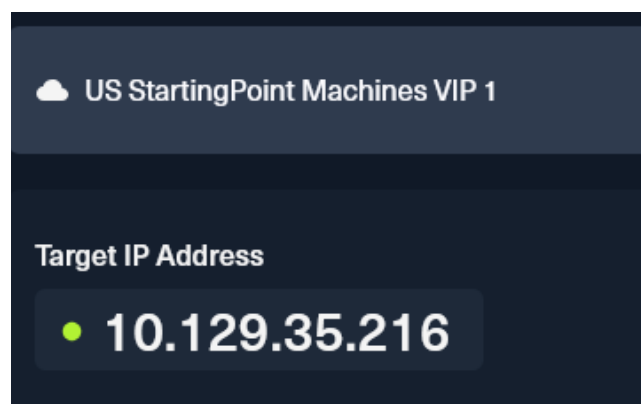


Figure 2: Target Machine Information

4.2 Network Information Gathering

For a majority of Hack the Box challenges, the starting point is an nmap scan. For this assessment we used the command: `nmap -p- -T5 -sC -sV 10.129.35.216`.

The result led to two ports being found:

- Port 21 for ftp
 - The scan also indicated that Anonymous FTP login was allowed
- Port 80 for http
 - Here we see the tile of the website, Smash

Further explanation of the specific flags and findings of the nmap scan will be in Section 7.

4.3 FTP Findings

Due to the results of the nmap scan, we were pointed in the direction of the ftp server hosted on the target machine. We accessed the ftp server using the command: `ftp 10.129.35.216`. FTP is defined in Section 9.

As indicated by the nmap scan we were able to connect with the username, anonymous which does not require a password. This allowed us to see two unencrypted files, `allowed.userlist` and `allowed.userlist.passwd` located on the ftp server. After downloading the files we were able to see a list of usernames and a list of passwords.

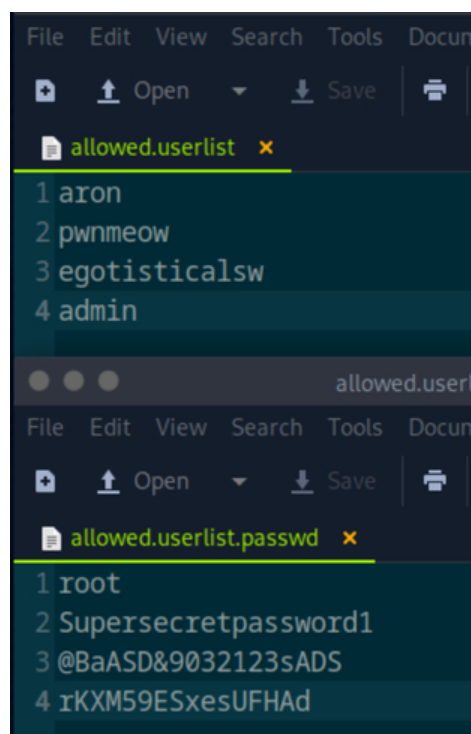


Figure 3: Userlist and Passwords

4.4 Hack the Box Tasks

The Starting Point section of Hack the Box machines use tasks to steer the student towards the intended vulnerability. Some of the guidance tasks teach students where to look for important information. In order to check the flag all tasks must be completed but for this particular box the most important task was: *What switch can we use with Gobuster to specify we are looking for specific filetypes?*

The answer to this question, '-x', pointed us to enumerating the IP address to find hidden information. For this box we were being guided to utilize gobuster with the -x flag to find .php files. This revealed the login.php file and once connected to the webpage, we were able to try the four passwords found in allowed.userlist.passwd, granting us admin level access.

4.5 Website Enumeration

Visiting <http://10.129.35.216> leads us to a website for Smash Bootstrap Business Template. While the website shows the business location, team members, and other useful information, it does not show a login portal to test the usernames and passwords we found.

In order to find the login page for the website being hosted on the target machine we needed to utilize the gobuster tool. In order to enumerate using gobuster we utilized the following command: `gobuster dir --url http://10.129.35.216/ --wordlist fasttrack.txt -x php`

This revealed the url <http://10.129.35.216/login.php>. For further information regarding gobuster and the flags and findings, refer to Section 8.

4.5 Administrative Access Validation

Now that we have found a login page all that remained was to test the various usernames and passwords we retrieved from the ftp server. Starting with the admin username, we tested all four passwords and we were able to gain access. This yielded the root flag to complete the box indicating that we found the administrator level of the machine. The login page and the page for administrator access can be seen in figures 4 and 5.

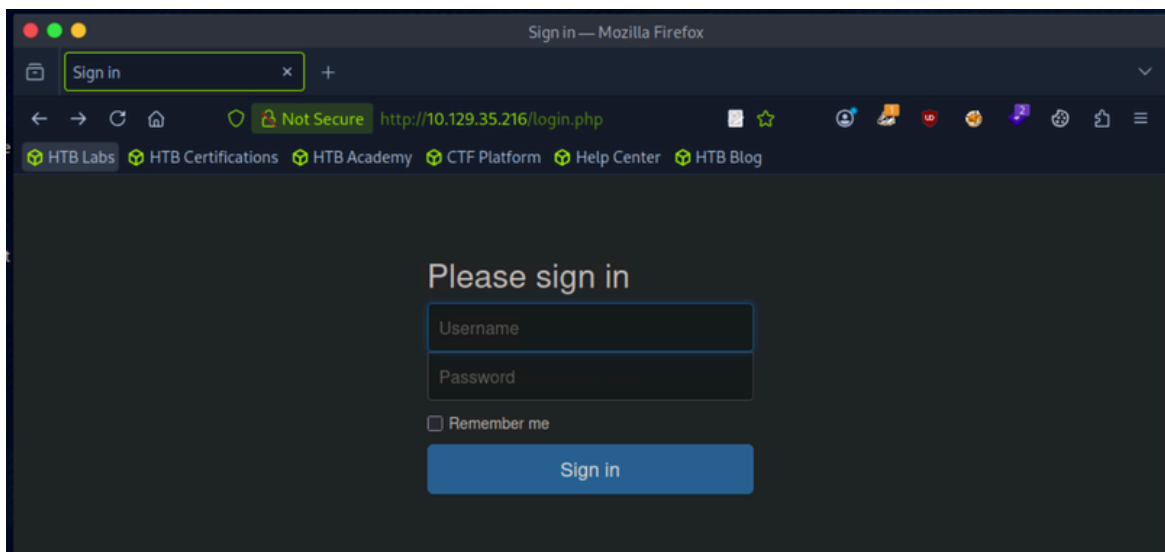


Figure 4: Login Page

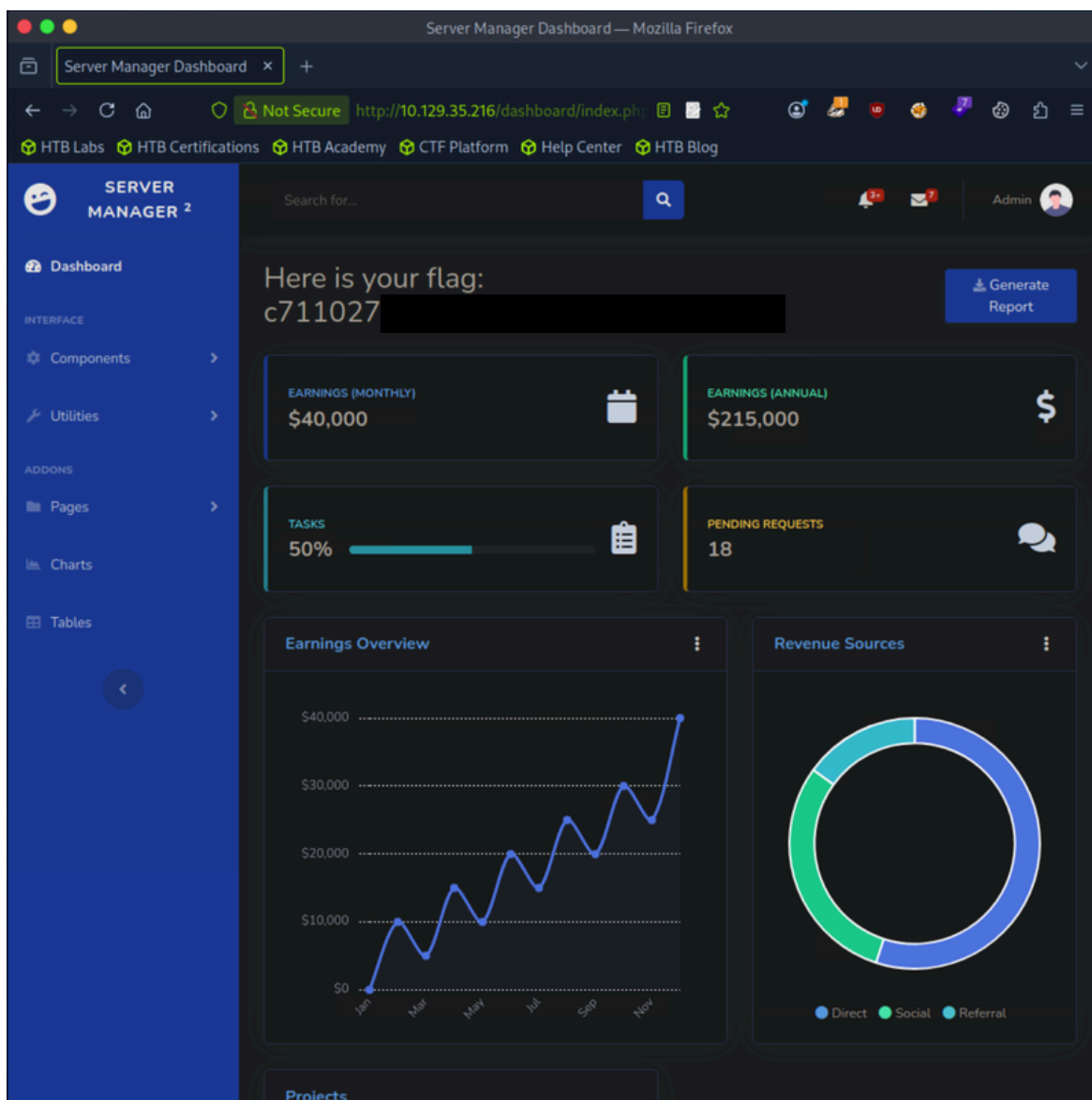


Figure 5: Administrator Page

5 Assessment Results and Recommendations

This section will review the findings and results from section 4. There will be sections for weaknesses, strengths, and observations.

We will use the following definitions:

- Weaknesses are anything that could potentially be used as an attack vector or lead to an attack. This should be seen as something to correct in order to mitigate risk and potential loss.
 - We will be including a rating system for the weaknesses listed to relate the significance of what had been found. This rating system will be ranked with the terms HIGH, MODERATE, and LOW. These ratings correlate to how significant their contribution was to the completion of Crocodile.
 - Hack the Box is made to be used by students to gain hands on experience, so complete mitigation would lead to an unusable testing environment. In order to practice report writing.
- Strengths are anything that would stop or restrict a potential attack. This should be seen as way to emphasize what works well in the box in regards to cyber security.
- Observations are anything else we find that we feel is important to include. As an example we could list something that could evolve into a weakness or something to monitor.

5.1 Weaknesses

(High) User lists and passwords are stored and transmitted in plaintext.

- Justification: Anybody connected to the network can access the ftp server and pull down the user list and their passwords. Since they are in plaintext, their contents can be viewed without any safeguards or protections. Despite the user list and their passwords being kept on separate files it becomes trivial to test each password against each user name. Since there are four users listed and four passwords listed there are at most sixteen different combinations that need to be tested.
- Mitigations: Encrypting the user list and the passwords will make it more difficult to brute force login credentials. File encryption should also be in place for important information so anyone observing the network would only find encrypted data.

(High) File Transfer Protocol has has been configured to allow for anonymous access

- Justification: The ftp server is currently allowing anybody to access the information stored on the server. Anonymous access is not a default setting for ftp servers and must be specifically configured.
- Mitigations: Using a proper password and username to access the ftp server data. Advising users to have as strong password would also help in data loss prevention.

(Moderate) Usage of file transfer protocol on Crocodile.

- Justification: File transfer protocol transmits data and credentials in plaintext. If a potential attacker was listening on the network then they could view login credentials used for the ftp server. Any data that was not encrypted would also be visible using ftp.
- Mitigations: Switching to SFTP or Secure File Transfer Protocol will encrypt the transmitted data and credentials. In our listener scenario, this would mean the listener only sees encrypted traffic over the network.

(Low) HTTP is used on Crocodile.

- Justification: HTTP does not encrypt its traffic over the network. This means that someone monitoring network traffic would see all HTTP responses and requests being made. Potentially allowing this listener to learn more about the network.
- Mitigations: Switching to HTTPS, or Hypertext Transfer Protocol Secure, would encrypt the communication. This means that a listener would not be able to see the contents made during requests and responses.

5.2 Strengths

Authentication Controls

- Visitors cannot create their own account on the website's login page.
- Password creation rules appear to be implemented as most of the passwords found are sufficiently long and contain extra characters.
- User lists and their passwords are kept separate.
- Despite Anonymous mode in place it shows an attempt to configure better security

Attack Surface

- Limited, the only vulnerabilities found were intended to be there by Hack the Box. This would apply to most boxes but is still worth including.

5.2 Observations

Implementing a log for access attempts would help in tracking various changes.

- Description: Given our level of access to Crocodile we are unsure if there is a log file or a system in place to track those who are moving about the system. Logins, for the website and ftp server, could be recorded and allow for review in the event there is a security concern.
- Recommendation: Adding a log file to track changes would allow for administrators to review logins and other information on the network. This could help in locating an instance when someone accessed information they should not have been able to or if there is malicious activity being recorded.

Implementing a rate limit on login attempts

- Description: There were 16 potential combinations to try on login.php and we were able to make attempts until we got to the correct combination. This shows a lack of a limit on the login attempts.
- Recommendation: Adding a rate limit would further increase security if the password and user file were obtained by a malicious actor.

6 Conclusion

During the assessment we found multiple vulnerabilities that were intended to be located by the staff at Hack the Box. Most of these vulnerabilities could be addressed by switching to a secure version of the various protocols currently used. This would cut down on unencrypted traffic but would make Crocodile, the box we assessed, significantly more difficult to complete for the average new user. The team also found several strengths of note in addition to a few observations that could help further secure the box.

The author would like to thank Hack the Box for their educational platform and their instructor, Benjamin Anderson, for inspiring them to pursue penetration testing as a career choice.

7 Appendix A: NMAP Scan

This section contains an appendix for the nmap scan. The definition of nmap was provided by ChatGPT

7.1 Definition

Nmap, short for Network Mapper, is a widely used open-source tool for network discovery and security auditing. It enables security professionals to identify live hosts, discover open ports, detect running services, and determine service versions across a network. Nmap can also perform operating system fingerprinting and execute specialized scripts for vulnerability detection and further enumeration. During a penetration test, Nmap is often one of the first tools used because it provides a comprehensive view of the target's network exposure and helps define the available attack surface.

7.2 Raw Output

We have included the raw output for the nmap scan to show the information the team was able to pull from the scan. See figure 6 for the raw output

```
File Edit View Search Terminal Help
[us-starting-point-vip-1-dhcp]-[10.10.14.127]-[sflemingiii@htb-1g9etiwy2s]-[~/Desktop]
[*]$ nmap -p- -T5 -sC -sV 10.129.35.216
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 11:01 CDT
Nmap scan report for 10.129.35.216
Host is up (0.0074s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--  1 ftp      ftp      33 Jun 08  2021 allowed.userlist
| -rw-r--r--  1 ftp      ftp      62 Apr 20  2021 allowed.userlist.passwd
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.10.14.127
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Smash - Bootstrap Business Template
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.65 seconds
```

Figure 6: Raw nmap Output

7.3 Command Explanation

The command we used for the nmap scan is as follows:

```
nmap -p- -T5 -sC -sV 10.129.35.216
```

Here is how each part breaks down:

- -p
 - This flag changes the ports we chose to scan. Normally nmap will scan the first 1000 ports but as a precaution we chose to scan all 65,535 ports hence the dash following the flag, -p-.
- -T5
 - This tells nmap to move as fast as possible. The scope of the test and the educational environment of Hack the Box allows for this to save time on the assessment. Normally, someone using nmap would try to be as secretive as possible. Since we were checking every port we included this flag to save time.
- -sC
 - This flag tells nmap to use the default scripts which gathers additional information when an open port is found.
- -sV
 - This flag will have nmap show the version information from the open ports that were found.
- 10.129.35.216
 - This is the target host, also known as Crocodile, that we are assessing.

7.4 Scan Summary

Findings can be summarized in the table

Port	Protocol	State	Service	Version
21	tcp	open	ftp	vsftpd 3.0.3
80	tcp	open	http	Apache httpd 2.4.41

We can also see that Login code 230 was found on the ftp server which indicates anonymous login is allowed. We also see the files allowed.userlist and allowed.userlist.passwd as being accessible through the ftp server.

8 Appendix B: GOBUSTER Scan

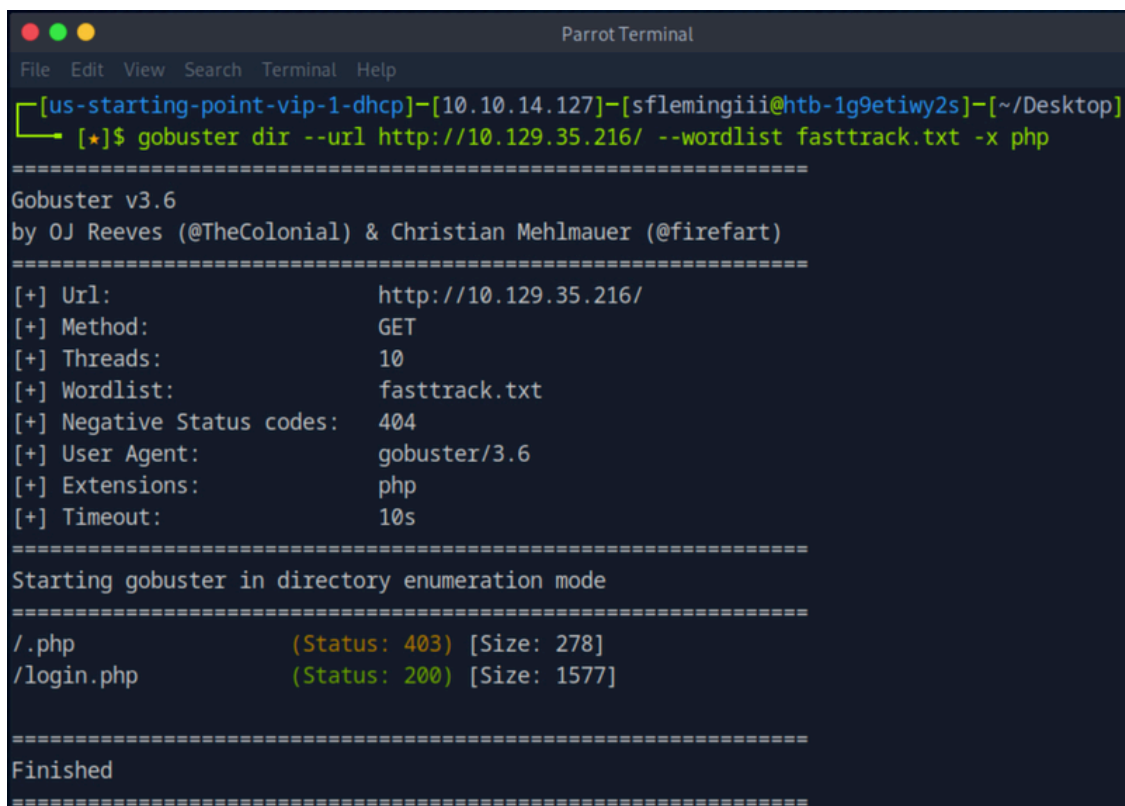
This section contains an appendix for the gobuster scan. The definition of gobuster was provided by ChatGPT

8.1 Definition

Gobuster is an open-source enumeration tool commonly used during penetration testing and security assessments. It is designed to discover hidden resources on web servers and other network services by performing brute-force searches against predefined wordlists. In web application testing, Gobuster is frequently used to identify undisclosed directories, files, subdomains, or virtual hosts that are not readily visible through normal browsing. By uncovering these hidden resources, testers can identify additional attack surfaces, such as administrative panels, backup files, or unprotected application components.

8.2 Raw Output

We have included the raw output for the gobuster scan to show the information the team was able to pull from the scan. See figure 7 for the raw output



```
Parrot Terminal
File Edit View Search Terminal Help
[us-starting-point-vip-1-dhcp]-[10.10.14.127]-[sflamingiii@htb-1g9etiwy2s]-[~/Desktop]
[+]$ gobuster dir --url http://10.129.35.216/ --wordlist fasttrack.txt -x php
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.35.216/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: fasttrack.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.php (Status: 403) [Size: 278]
/login.php (Status: 200) [Size: 1577]
=====
Finished
=====
```

Figure 7: Raw gobuster Output

8.3 Command Explanation

The command we used for the nmap scan is as follows:

```
gobuster dir --url http://10.129.35.216/ --wordlist fasttrack.txt -x php
```

Here is how each part breaks down:

- `dir`
 - Dir stands for directory or file enumeration mode which means that gobuster will brute force paths on the web server in order to find hidden pages
- `--url`
 - This is our target, since nmap revealed there is an http service running on port 80 and we were able to confirm a webpage present we wanted to find more information.
- `--wordlist`
 - This flag indicates the next string is the file to be used as a word list for this command the word list is fasttrack.txt. In this case, Pwnbox provides multiple lists, we chose a shorter list of only around 220 words to check. If nothing had come up we would have moved on to a larger list but fortunately we were able to find the login page with this one.
- `-x`
 - This tells gobuster to append an extension when enumerating. We chose php per the guidance track from Hack the Box. Without this flag, we would not have found the login.php page.

8.4 Scan Summary

As the raw output shows there are two files that are found with the enumeration. The first returns error code 403 for the file .php which means that gobuster couldnt access the information. Since its a response beyond 404 it was included in the results. The second one shows code 200 which is a successful code for http indicating that login.php was present on the web server.

9 Appendix C: Additional Definitions

This section contains an appendix for additional definitions of protocols mentioned in the report. The definitions were provided by ChatGPT

9.1 FTP

File Transfer Protocol (FTP) is a standard network protocol used to transfer files between a client and a server over a TCP/IP network. It allows users to upload, download, rename, and manage files on remote systems. FTP typically operates over port 21 for command and control communications, with additional ports used for data transfer. Because traditional FTP transmits credentials and data in plaintext, it is considered insecure for use over untrusted networks. In penetration testing, FTP services are often examined for weak credentials, anonymous access, misconfigurations, or exposed sensitive files.

9.2 HTTP

Hypertext Transfer Protocol (HTTP) is the foundational application-layer protocol used for transmitting web content across the Internet. It facilitates communication between web clients, such as browsers, and web servers by defining how requests and responses are formatted and exchanged. HTTP is responsible for delivering web pages, images, scripts, and other resources. By default, HTTP operates over port 80. Since standard HTTP traffic is transmitted in plaintext, it lacks built-in confidentiality and integrity protections. For secure communication, it is commonly replaced by HTTPS, which encrypts traffic using Transport Layer Security (TLS). In penetration testing, HTTP services are a primary focus because they often host web applications that may contain vulnerabilities such as misconfigurations, authentication flaws, or insecure coding practices.